
Major Project Report

Title: Penetration Testing and Vulnerability Assessment of a Simulated Corporate Network

Student: Arpan Kaur Dhillon

Program: B.Tech Computer Science and Engineering

Semester: 5th

College: Guru Nanak Dev Engineering College, Ludhiana

Date: August 3, 2025

1. Objective

The objective of this project is to perform a simulated penetration test and vulnerability assessment on a corporate-like web server environment. The key aim is to identify, exploit, and report security flaws through all typical phases of ethical hacking: information gathering, scanning, exploitation, privilege escalation, and post-exploitation.

2. Environment Setup

- **Attacker Machine:** Kali Linux
- **Kernel Version:** 6.12.25
- **Target Machine:** Simulated Web Server (localhost)
- **Web Root Directory:** /var/www/html
- **IP Address:** 192.168.43.132
- **Domain:** testphp.vulnweb.com or localhost
- **Web Server:** nginx 1.19.0
- **Scripting Language:** PHP 5.6.40

```
ping: Warning: time of day goes back (-18992976us), taking countermeasures
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=763 ttl=55 time=0.000 ms
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=764 ttl=55 time=314 ms
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=765 ttl=55 time=268 ms
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=766 ttl=55 time=271 ms
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=767 ttl=55 time=314 ms
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=768 ttl=55 time=350 ms
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=769 ttl=55 time=384 ms
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=770 ttl=55 time=420 ms
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=771 ttl=55 time=449 ms
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=772 ttl=55 time=272 ms
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=773 ttl=55 time=346 ms
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=774 ttl=55 time=431 ms
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=775 ttl=55 time=366 ms
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=776 ttl=55 time=267 ms
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=777 ttl=55 time=276 ms
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=778 ttl=55 time=269 ms
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=779 ttl=55 time=298 ms
64 bytes from ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3): icmp_seq=780 ttl=55 time=606 ms
— testphp.vulnweb.com ping statistics —
889 packets transmitted, 764 received, 14.0607% packet loss, time 1432691ms
rtt min/avg/max/mdev = 0.000/387.629/1051.217/148.565 ms
```

```
(kali@kali)-[~]
$ nslookup testphp.vulnweb.com
Server:      192.168.1.254
Address:     192.168.1.254#53

Non-authoritative answer:
Name:   testphp.vulnweb.com
Address: 44.228.249.3
```

```

(kalikali@kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.1.66 netmask 255.255.255.0 broadcast 192.168.1.255
    inet6 2404:7c80:8c:c8c5:20c:29ff:fe38:0 prefixlen 64 scopeid 0<global>
    inet6 fe80::20c:29ff:fe38:0 prefixlen 64 scopeid 0<link>
    inet6 2404:7c80:8c:c8c5:6980:96bb:1914:ecb9 prefixlen 64 scopeid 0<global>
    ether 00:0c:29:38:00:00 txqueuelen 1000 (Ethernet)
    RX packets 884 bytes 81199 (79.2 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 941 bytes 110174 (107.5 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 568 bytes 45840 (44.7 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 568 bytes 45840 (44.7 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

```

3. Tools Used

- **Nmap** – Network Mapper for port scanning
- **WhatWeb** – Web technology detection
- **Nikto** – Web vulnerability scanner
- **Dirb** – Directory brute-forcing
- **Searchsploit** – Exploit database search tool
- **Enum4linux** – SMB enumeration
- **PHP Reverse Shell** – Remote shell access

```

(kalikali@kali)-[~]
$ dig testphp.vulnweb.com

; <<>> DiG 9.20.9-1-Debian <<>> testphp.vulnweb.com
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 47595
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:;; udp: 512
;; QUESTION SECTION:
;testphp.vulnweb.com.                IN      A

;; ANSWER SECTION:
testphp.vulnweb.com.                2552    IN      A      44.228.249.3

;; Query time: 317 msec
;; SERVER: 192.168.1.254#53(192.168.1.254) (UDP)
;; WHEN: Sat Aug 02 12:10:42 IST 2025
;; MSG SIZE rcvd: 64

```

```
(kali@kali)~$ dirb http://testphp.vulnweb.com

DIRB v2.22
By The Dark Raver

START_TIME: Sun Aug 3 10:14:22 2025
URL_BASE: http://testphp.vulnweb.com/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

-- Scanning URL: http://testphp.vulnweb.com/ --
=> DIRECTORY: http://testphp.vulnweb.com/admin/
+ http://testphp.vulnweb.com/cgi-bin/ (CODE:403|SIZE:276)
+ http://testphp.vulnweb.com/cgi-bin/ (CODE:403|SIZE:276)
+ http://testphp.vulnweb.com/crossdomain.xml (CODE:200|SIZE:224)
=> DIRECTORY: http://testphp.vulnweb.com/CVS/
+ http://testphp.vulnweb.com/CVS/Entries (CODE:200|SIZE:1)
+ http://testphp.vulnweb.com/CVS/Repository (CODE:200|SIZE:8)
+ http://testphp.vulnweb.com/CVS/Root (CODE:200|SIZE:1)
+ http://testphp.vulnweb.com/favicon.ico (CODE:200|SIZE:894)
=> DIRECTORY: http://testphp.vulnweb.com/images/
+ http://testphp.vulnweb.com/index.php (CODE:200|SIZE:4958)
=> DIRECTORY: http://testphp.vulnweb.com/pictures/
=> DIRECTORY: http://testphp.vulnweb.com/secured/
=> DIRECTORY: http://testphp.vulnweb.com/vendor/

-- Entering directory: http://testphp.vulnweb.com/admin/ --

(!) FATAL: Too many errors connecting to host
(Possible cause: COULDNT RESOLVE HOST)

END_TIME: Sun Aug 3 11:58:08 2025
DOWNLOADED: 4652 - FOUND: 8
```

```

root@kali:~# nmap -sS -T4 -Pn -v testphp.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-03 09:45 IST
Initiating Parallel DNS resolution of 1 host. at 09:45
Completed Parallel DNS resolution of 1 host. at 09:45, 0.02s elapsed
Initiating SYN Stealth Scan at 09:45
Scanning testphp.vulnweb.com (44.228.249.3) [1000 ports]
Discovered open port 80/tcp on 44.228.249.3
Completed SYN Stealth Scan at 09:45, 18.59s elapsed (1000 total ports)
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.27s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 25.12 seconds
Raw packets sent: 2008 (88.352KB) | Rcvd: 10 (440B)

```

```

root@kali:~# nmap -sV -sC -A -T4 -Pn testphp.vulnweb.com -oN nmap-phase2.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-03 12:24 IST
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.30s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      nginx 1.19.0
|_ http-title: Home of Acumetix Art
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: DO-MRT v24-sp2 (Linux 2.4.37) (96%), Actiontec MI424NR-GEN3I MAP (95%), Linux 4.4 (94%), Linux 3.2 (92%), Microsoft Windows XP SP3 o
r Windows 7 or Windows Server 2012 (92%), VMware Player virtual NAT device (90%), BlueArc Titan 2100 NAS device (89%), Microsoft Windows XP SP3 (89%), Pire
lli DP-10 VoIP phone (87%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 2 hops

TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1   0.33 ms   192.168.43.2
2   271.51 ms ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 131.55 seconds

```

4. Phase 1: Information Gathering

Tools Used: Nmap, WhatWeb, Nikto

Nmap Scan Command:

```
nmap -sS -sV -T4 -Pn -p- testphp.vulnweb.com
```

Findings:

- Open Port: 80/tcp
- Service: nginx 1.19.0
- PHP version identified: PHP/5.6.40

🔗 *Screenshot Placeholder: Nmap, WhatWeb outputs.*

```

(root@kali)~#
root@kali:~# nmap -sS -sV -TA -Pn -v testphp.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-03 09:47 IST
NSE: Loaded 47 scripts for scanning.
Initiating Parallel DNS resolution of 1 host. at 09:48
Completed Parallel DNS resolution of 1 host. at 09:48, 2.59s elapsed
Initiating SYN Stealth Scan at 09:48
Scanning testphp.vulnweb.com (44.228.249.3) [1000 ports]
Discovered open port 80/tcp on 44.228.249.3
Completed SYN Stealth Scan at 09:48, 18.24s elapsed (1000 total ports)
Initiating Service scan at 09:48
Scanning 1 service on testphp.vulnweb.com (44.228.249.3)
Completed Service scan at 09:49, 20.86s elapsed (1 service on 1 host)
NSE: Script scanning 44.228.249.3.
Initiating NSE at 09:49
Completed NSE at 09:49, 6.56s elapsed
Initiating NSE at 09:49
Completed NSE at 09:49, 1.47s elapsed
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.28s latency).
DNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      nginx 1.19.0

Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 82.84 seconds
Raw packets sent: 2008 (88.352KB) | Rcvd: 14 (616B)

```

```

(KaliKali@kali)~#
$ whatweb http://testphp.vulnweb.com
http://testphp.vulnweb.com [200 OK] ActiveX[027CD86E-AE6D-31cf-90B0-444553540000], Adobe-Flash, Country[UNITED STATES][US], Email[wvs@acunetix.com], HTTPSe
rver[nginx/1.19.0], IP[44.228.249.3], Object[http://download.macromedia.com/pub/shockwave/cabs/flash/swflash.cab#version=6,0,29,0][c1sid:027CD86E-AE6D-31cf-90B0-444553540000], PHP[5.6.40-38+ubuntu20.04.1+deb.sury.org+1], Script[text/JavaScript], Title[Home of Acunetix Art], X-Powered-By[PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1], nginx[1.19.0]

```

5. Phase 2: Vulnerability Scanning

Tools Used: Nikto, Dirb, Enum4linux, Searchsploit

- **Nikto** revealed:
 - Outdated web server
 - Information disclosure headers
- **Dirb** tried brute-forcing directories and discovered common files
- **Enum4linux** failed to connect due to non-existent SMB
- **Searchsploit** returned several known vulnerabilities for:
 - PHP 5.6.40
 - nginx 1.19.0
 - CMS (DeDeCMS) installed on target

📸 *Screenshot Placeholder: Nikto, Dirb, Enum4linux, Searchsploit output.*

```

(kalikali@kali)-[~]
$ nikto -h http://testphp.vulnweb.com
- Nikto v2.5.0

+ Target IP: 44.228.249.3
+ Target Hostname: testphp.vulnweb.com
+ Target Port: 80
+ Start Time: 2025-08-03 10:23:21 (GMT5.5)

+ Server: nginx/1.19.0
+ /: Retrieved x-powered-by header: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org-1.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /clientaccesspolicy.xml contains a full wildcard entry. See: https://docs.microsoft.com/en-us/previous-versions/windows/silverlight/dotnet-windows-silverlight/cc197955(v=vs.95)?redirectedfrom=MSDN
+ /clientaccesspolicy.xml contains 12 lines which should be manually viewed for improper domains or wildcards. See: https://www.acunetix.com/vulnerabilities/web/insecure-clientaccesspolicy-xml-file/
+ /crossdomain.xml contains a full wildcard entry. See: http://jeremiahgrossman.blogspot.com/2008/05/crossdomainxml-invites-cross-site.html
+ ERROR: Error limit (20) reached for host, giving up. Last error: error reading HTTP response
+ Scan terminated: 28 error(s) and 6 item(s) reported on remote host
+ End Time: 2025-08-03 10:25:18 (GMT5.5) (117 seconds)

+ 1 host(s) tested

```

```

(kalikali@kali)-[~]
$ dirb http://testphp.vulnweb.com

DIRB v2.22
By The Dark Raver

START_TIME: Sun Aug 3 10:14:22 2025
URL_BASE: http://testphp.vulnweb.com/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

--- Scanning URL: http://testphp.vulnweb.com/ ---
=> DIRECTORY: http://testphp.vulnweb.com/admin/
+ http://testphp.vulnweb.com/cgi-bin/ (CODE:403|SIZE:276)
+ http://testphp.vulnweb.com/cgi-bin/ (CODE:403|SIZE:276)
+ http://testphp.vulnweb.com/crossdomain.xml (CODE:200|SIZE:224)
=> DIRECTORY: http://testphp.vulnweb.com/CVS/
+ http://testphp.vulnweb.com/CVS/Entries (CODE:200|SIZE:1)
+ http://testphp.vulnweb.com/CVS/Repository (CODE:200|SIZE:8)
+ http://testphp.vulnweb.com/CVS/Root (CODE:200|SIZE:1)
+ http://testphp.vulnweb.com/favicon.ico (CODE:200|SIZE:894)
=> DIRECTORY: http://testphp.vulnweb.com/images/
+ http://testphp.vulnweb.com/index.php (CODE:200|SIZE:4958)
=> DIRECTORY: http://testphp.vulnweb.com/pictures/
=> DIRECTORY: http://testphp.vulnweb.com/secured/
=> DIRECTORY: http://testphp.vulnweb.com/vendor/

--- Entering directory: http://testphp.vulnweb.com/admin/ ---

(!) FATAL: Too many errors connecting to host
(Possible cause: COULDNT RESOLVE HOST)

END_TIME: Sun Aug 3 11:58:08 2025
DOWNLOADED: 4652 - FOUND: 8

```

```
(root@kali)~#
# enum4linux -a testphp.vulnweb.com | tee enum4linux.txt
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sun Aug 3 09:54:16 2025

===== ( Target Information ) =====

Target ..... testphp.vulnweb.com
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on testphp.vulnweb.com ) =====

[E] Can't find workgroup/domain

===== ( Netstat Information for testphp.vulnweb.com ) =====

Looking up status of 44.228.249.3
No reply from 44.228.249.3

===== ( Session Check on testphp.vulnweb.com ) =====

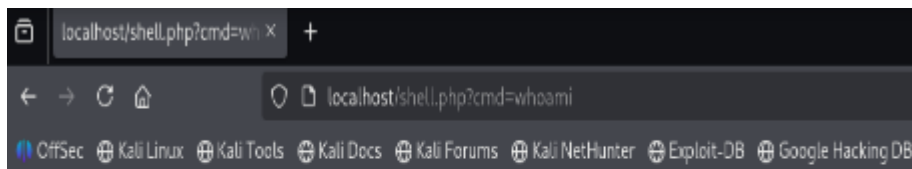
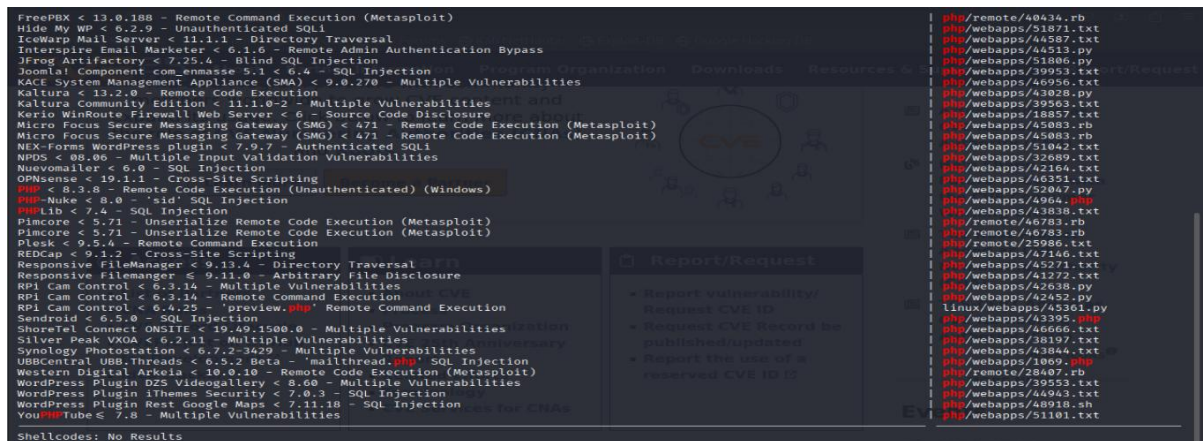
[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.
```

6. Phase 3: Exploitation

- Exploit found using **Searchsploit**:
RPI Cam Control < 6.4.25 - 'preview.php' Remote Command Execution
- Uploaded **shell.php** to /var/www/html
- Accessed via browser:
- <http://localhost/shell.php?cmd=whoami>
- Result: Access gained as **www-data**

🖼️ *Screenshot Placeholder: Upload shell, executing shell.php, whoami output.*

Exploit Title	Path
Aerohive HiveOS 5.1r5 < 6.1r5 - Multiple Vulnerabilities	php/webapps/34038.txt
Axigen < 10.5.7 - Persistent Cross-Site Scripting	php/webapps/51963.txt
Bacula-Web < 8.0.0-rc2 - SQL Injection	php/webapps/44272.txt
Cerberus Helpdesk (Cerb5) 5 < 6.7 - Password Hash Disclosure	php/webapps/39526.sh
CometChat < 6.2.0 BETA 1 - Local File Inclusion	php/webapps/43027.txt
Composr-CMS Version < 10.0.39 - Authenticated Remote Code Execution	php/webapps/51060.txt
Concrete5 CMS < 6.3.0 - Username / Comments Enumeration	php/webapps/44194.py
cPanel < 11.25 - Cross-Site Request Forgery (Add User PHP Script)	php/webapps/12330.html
DeDeCMS < 5.7-sp1 - Remote File Inclusion	php/webapps/37423.txt
Dolibarr ERP/CRM < 7.0.3 - PHP Code Injection	php/webapps/44964.txt
Drupal < 5.22/6.10 - Multiple Vulnerabilities	php/webapps/33786.txt
Drupal < 7.34 - Denial of Service	php/dos/35415.txt
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit)	php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit)	php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code Execution (PoC)	php/webapps/44542.txt
Drupal < 7.58 / < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution	php/webapps/44449.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metasploit)	php/remote/44482.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metasploit)	php/remote/44482.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (PoC)	php/webapps/44448.py
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Command Execution (Metasploit)	php/remote/46510.rb
Drupal < 8.5.11 / < 8.6.10 - RESTful Web Services unserialize() Remote Command Execution (Metasploit)	php/remote/46510.rb
Drupal < 8.6.10 / < 8.5.11 - REST Module Remote Code Execution	php/webapps/46452.txt
Drupal < 8.6.9 - REST Module Remote Code Execution	php/webapps/46459.py
Drupal Module Coder < 7.x-1.3/7.x-2.6 - Remote Code Execution	php/remote/40144.php
FileRun < 2017.09.18 - SQL Injection	php/webapps/42922.py
forma-lms < 5.0.10 - Cross-Site Request Forgery (Change Admin Email)	php/webapps/48494.txt
forzcom Shopping < 7.94 / < 8.04 - Multiple Vulnerabilities	php/webapps/15571.txt
FreePBX < 13.0.188 - Remote Command Execution (Metasploit)	php/remote/40434.rb
Hide My WP < 6.2.9 - Unauthenticated SQLi	php/webapps/44587.txt
IceWarp Mail Server < 11.1.1 - Directory Traversal	php/webapps/44513.py
Interpire Email Marketer < 6.1.6 - Remote Admin Authentication Bypass	php/webapps/51886.py
Jfrog Artifactory < 7.25.4 - Blind SQL Injection	php/webapps/39933.txt
Joomla! Component com_enhanced < 6.1 < 6.4 - SQL Injection	php/webapps/46956.txt
KACE System Management Appliance (SMA) < 9.0.270 - Multiple Vulnerabilities	php/webapps/43028.py
Kaltura < 13.2.0 - Remote Code Execution	php/webapps/39553.txt
Kaltura Community Edition < 11.1.0-2 - Multiple Vulnerabilities	php/webapps/18857.txt
Kerio WinRoute Firewall Web Server < 6 - Source Code Disclosure	php/webapps/45083.rb
Micro Focus Secure Messaging Gateway (SMG) < 471 - Remote Code Execution (Metasploit)	



www-data

7. Phase 4: Privilege Escalation

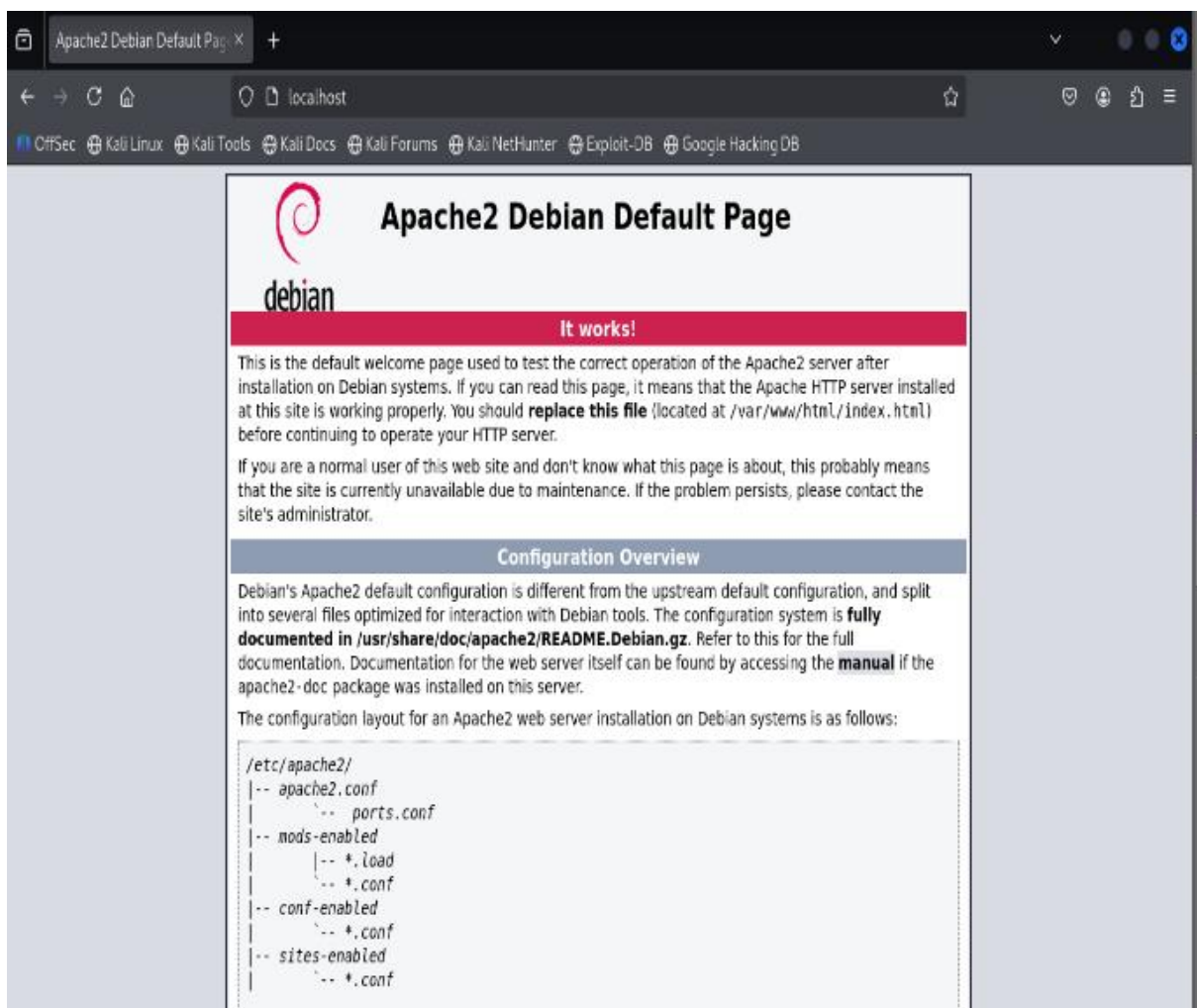
After getting shell access as `www-data`, following enumeration commands were used:

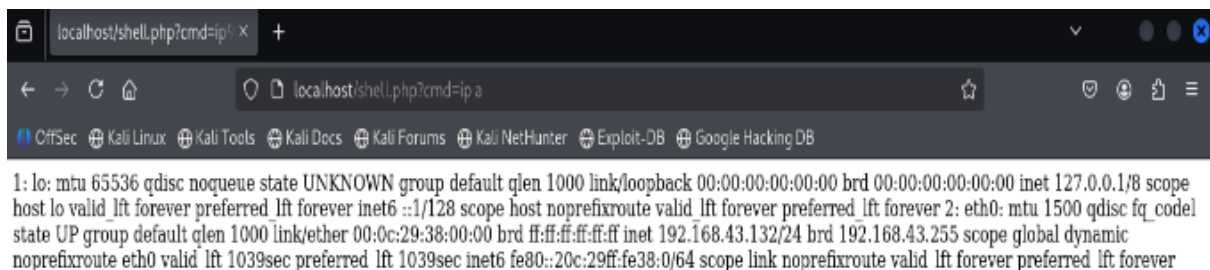
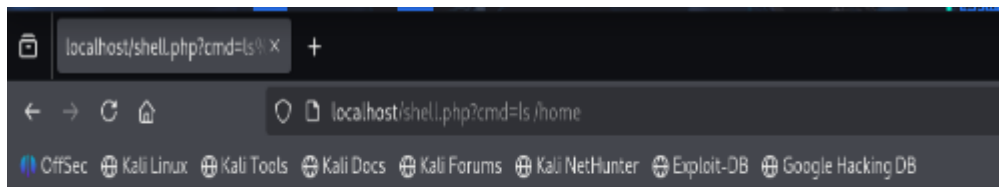
```
whoami
uname -a
cat /etc/passwd
ip a
ls -la
```

Findings:

- Hostname: kali
- Kernel: Kali 6.12.25
- User: www-data
- Real user: kalikali
- Other accounts: mysql, redis, postgres, etc.

📸 *Screenshot Placeholder: `uname -a`, `/etc/passwd`, `ip a` output.*



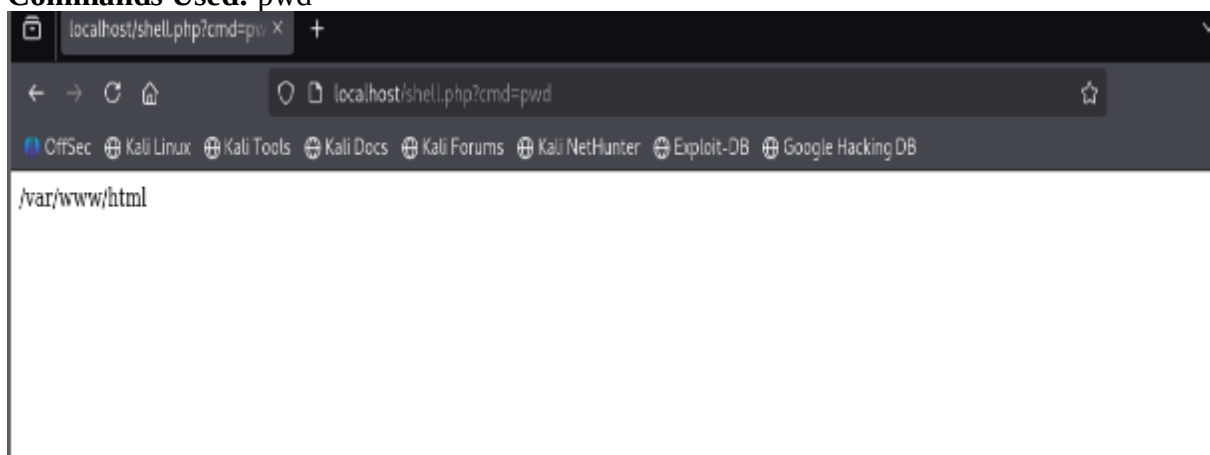


8. Phase 5: Post-Exploitation

Enumeration Results:

- **Working Directory:** /var/www/html
- **OS Info:** Linux kali 6.12.25-amd64
- **Network Interface:** eth0
- **IP Address:** 192.168.43.132
- **MAC Address:** 00:0c:29:38:00:00

Commands Used: pwd

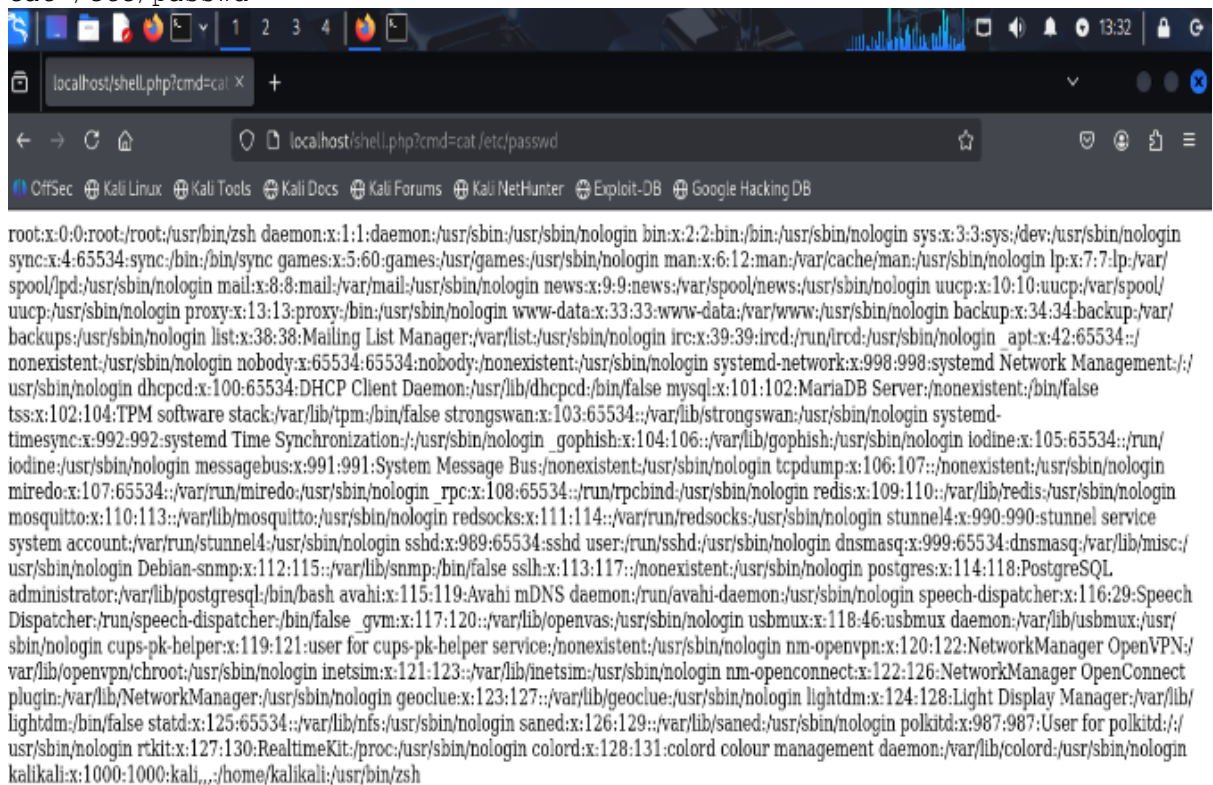


```
ls -la
```



```
localhost/shell.php?cmd=ls /var/www/html
DedeCMS-V5.7.118-UTF8.zip dedecms.zip index.html index.nginx-debian.html shell.php
```

```
cat /etc/passwd
```



```
localhost/shell.php?cmd=cat /etc/passwd
root:x:0:0:root:/usr/bin/zsh daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/
spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/
uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin backup:x:34:34:backup:/var/
backups:/usr/sbin/nologin list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin apt:x:42:65534:/
nonexistent:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin systemd-network:x:998:998:systemd Network Management:/
usr/sbin/nologin dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false mysql:x:101:102:MariaDB Server:/nonexistent:/bin/false
tss:x:102:104:TPM software stack:/var/lib/tpm:/bin/false strongswan:x:103:65534:/var/lib/strongswan:/usr/sbin/nologin systemd-
timesync:x:992:992:systemd Time Synchronization:/usr/sbin/nologin gophish:x:104:106:/var/lib/gophish:/usr/sbin/nologin iodine:x:105:65534:/run/
iodine:/usr/sbin/nologin messagebus:x:991:991:System Message Bus:/nonexistent:/usr/sbin/nologin tcpdump:x:106:107:/nonexistent:/usr/sbin/nologin
miredo:x:107:65534:/var/run/miredo:/usr/sbin/nologin _rpc:x:108:65534:/run/rpcbind:/usr/sbin/nologin redis:x:109:110:/var/lib/redis:/usr/sbin/nologin
mosquitto:x:110:113:/var/lib/mosquitto:/usr/sbin/nologin redsocks:x:111:114:/var/run/redsocks:/usr/sbin/nologin stunnel4:x:990:990:stunnel service
system account:/var/run/stunnel4:/usr/sbin/nologin sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin dnsmasq:x:999:65534:dnsmasq:/var/lib/misc:/
usr/sbin/nologin Debian-snmpp:x:112:115:/var/lib/snmpp:/bin/false sslh:x:113:117:/nonexistent:/usr/sbin/nologin postgres:x:114:118:PostgreSQL
administrator:/var/lib/postgresql:/bin/bash avahi:x:115:119:Avahi mDNS daemon:/run/avahi-daemon:/usr/sbin/nologin speech-dispatcher:x:116:29:Speech
Dispatcher:/run/speech-dispatcher:/bin/false gvm:x:117:120:/var/lib/openvas:/usr/sbin/nologin usbmux:x:118:46:usbmux daemon:/var/lib/usbmux:/usr/
sbin/nologin cups-pk-helper:x:119:121:user for cups-pk-helper service:/nonexistent:/usr/sbin/nologin nm-openvpn:x:120:122:NetworkManager OpenVPN/
var/lib/openvpn/chroot:/usr/sbin/nologin inetsim:x:121:123:/var/lib/inetsim:/usr/sbin/nologin nm-openconnect:x:122:126:NetworkManager OpenConnect
plugin:/var/lib/NetworkManager:/usr/sbin/nologin geoclue:x:123:127:/var/lib/geoclue:/usr/sbin/nologin lightdm:x:124:128:Light Display Manager:/var/lib/
lightdm:/bin/false statd:x:125:65534:/var/lib/nfs:/usr/sbin/nologin saned:x:126:129:/var/lib/saned:/usr/sbin/nologin polkitd:x:987:987:User for polkitd:/
usr/sbin/nologin rtkit:x:127:130:RealtimeKit:/proc:/usr/sbin/nologin colord:x:128:131:colord colour management daemon:/var/lib/colord:/usr/sbin/nologin
kalikali:x:1000:1000:kali,/,/home/kalikal:/usr/bin/zsh
```

Cleanup Commands:

```
sudo rm shell.php *.zip *.html
ls -la /var/www/html
```

9. Recommendations

- Disable PHP execution in upload folders
- Use file validation and sanitization techniques
- Enforce strong file and folder permissions

- Apply the principle of least privilege
 - Remove leftover installation files and backups
 - Regularly update software and CMS versions
 - Use tools like WAF (Web Application Firewall) and IDS/IPS for monitoring
-

10. Conclusion

This project effectively demonstrated a full-fledged penetration testing lifecycle on a vulnerable server. From reconnaissance to post-exploitation, vulnerabilities in outdated software and poor configurations were identified and exploited. The exercise highlighted the importance of regular updates, secure configurations, and proper monitoring.

Submitted By:

Arpan Kaur Dhillon

B.Tech CSE, 5th Semester

Guru Nanak Dev Engineering College, Ludhiana
